

SRC-0030 - Assessing the usefulness of Data Flow Diagrams for validating security threats

Domanda standard 1/4 - Qual e il problema di ricerca e qual e il contributo?

Identita, confronto causale, contributo empirico e confini della fonte

Identita	Mbaka, Zhang, Wang, Li, Massacci e Tuma (2025), Computers & Security 156, art. 104498.
Stable identifier	DOI 10.1016/j.cose.2025.104498
PDF letto	SRC-0030-mbaka-et-al-2025.pdf
SHA-256 sorgente	50bd229227dc204a64efb2e57f5ebe26d8c7a7c807a9f86d2cc281713a8c23fb
Evidenza	Esperimento controllato + confirming experiment; 98 studenti in due paesi.
Classificazione	documentation_plus_model: testo strutturato e modelli preparati manualmente.

Problema

I DFD sono comunemente costruiti per STRIDE, ma possono diventare obsoleti durante il raffinamento del design. La fonte valuta se mantenerli e consultarli migliori la validazione di minacce gia identificate.

Confronto sperimentale reale

scenario + sequence diagram + threat material versus scenario + sequence diagram + threat material + DFD
--

Contributi

- RQ1: effetto del DFD sulla correttezza di analisti novizi.
- RQ2: utilita percepita del DFD rispetto al sequence diagram.
- Due scenari comparabili: Kubernetes e GitHub commit/push.
- Misure separate di actual effectiveness e perceived usefulness.
- Replication package dichiarato con materiali, ground truth e script.

Centralita per DDTA

La fonte sfida una possibile assunzione DFD-centrica: un diagramma aggiuntivo puo essere percepito come utile senza produrre un miglioramento misurabile. Per DDTA, ogni vista va valutata rispetto a un task, una baseline e un outcome espliciti.

Confini

- Non valuta threat elicitation.
- Non confronta il DFD con nessun modello.
- Non studia esperti, manutenzione longitudinale o document-to-model extraction.
- Non dimostra che i DFD siano inutili in generale.

SRC-0030 - Assessing the usefulness of Data Flow Diagrams for validating security threats

Domanda standard 2/4 - Quali sono gli artefatti iniziali e come vengono rappresentati?

Input, viste, threat record, information cue e ground truth

Artefatti forniti a tutti

- Descrizione testuale dello scenario e formazione STRIDE.
- Sequence diagram con interazioni ordinate.
- Dieci minacce: cinque actual e cinque fabricated.
- Per ogni minaccia: description, assumption, STRIDE category e affected components.
- Questionari di ingresso e uscita.

Intervento

Solo il gruppo A riceve anche il DFD e la relativa formazione.

Rappresentazione DFD

Elementi	Processi, data store, data flow, external entity e trust boundary.
GitHub	Local Git Service, log, scheduler, GitHub engine, Actions, remote repository e flussi commit/push.
Kubernetes	API Server, etcd, scheduler/controller, kubelet, Docker, image repository, pod e worker node.
Controllo	Topologia, numero di elementi e sequenze resi comparabili fra i due scenari.

Threat record e fabricated threat

La validita non e derivata dal solo diagramma. Ogni giudizio usa description e assumption. Le minacce fabbricate contengono una contraddizione controllata: l'assunzione nega una capacita necessaria all'attacco.

Information cue

assumption / scenario text / graphical cue / external technical knowledge
-> actual or fabricated judgment

- Easy: decisione basata sull'assunzione.
- Medium: serve testo, diagramma o entrambi.
- Hard: serve conoscenza tecnica non fornita dagli artefatti.

Limite documentation-first

Gli artefatti sono costruiti dai ricercatori. La fonte non definisce qualita minima, provenance o trasformazione da documentazione eterogenea. Il DFD e una proiezione informativa, non una fonte completa.

SRC-0030 - Assessing the usefulness of Data Flow Diagrams for validating security threats

Domanda standard 3/4 - Come funzionano traceability, change, automation e ruolo umano?

Catena evidenziale, processo sperimentale, mantenimento e responsabilita

Catena di traceability osservata

```
scenario + diagrams
-> structured threat + assumption
-> information cue / technical knowledge
-> participant judgment
-> expert-curated ground truth
-> TP / TN / perception metrics
```

Procedura

- 1. Questionario iniziale e randomizzazione.
- 2. Due ore di training e studio del caso.
- 3. Due ore per classificare dieci minacce individualmente.
- 4. Questionario di uscita su utilita percepita e controlli.
- 5. Confronto con ground truth e conteggio TP, TN e TP+TN.
- 6. Test di differenza, equivalenza e correlazione.

Ruolo umano

Ricercatori	Creano DFD/sequence diagram, threat list, rationale e ground truth.
Partecipanti	Interpretano artefatti e conoscenza tecnica per giudicare le minacce.
Review	Ground truth discussa dal gruppo di sperimentatori, non indipendente dagli autori.
Automazione	Solo script statistici dichiarati; nessuna automazione del threat-analysis workflow.

Change ed evoluzione

- Il paper riconosce che il DFD puo diventare out-of-sync.
- Non misura update effort, stale detection, change impact o synchronization con il codice.
- La sostenibilita dalla progettazione al deployment resta open question.

Controlli richiesti a DDTA

- Provenance assertion-level per fatti, flussi, assunzioni e threat rationale.
- Distinzione extracted / inferred / analyst-supplied.
- Versioni e stale detection quando cambiano documenti, architettura o attacker profile.
- Evidenza separata per visualizzazione, correttezza, costo di review e mantenimento.

Disciplina

```
perceived usefulness != actual effectiveness
no significant difference != exact equality
replication package declared != independent replication executed
```

SRC-0030 - Assessing the usefulness of Data Flow Diagrams for validating security threats

Domanda standard 4/4 - Quali sono risultati, limiti e rapporto con DDTA/overlay?

Risultati statistici, validità, Base Analysis e uso nella tesi

Risultati reali

Differenza	Nessuna differenza significativa per TP, TN o TP+TN in entrambi gli esperimenti.
Equivalenza	Con $\Delta=1$: TP e TN equivalenti separatamente; TP+TN non equivalente ($p=0.18$ e $p=0.06$).
Percezione	DFD percepito più utile del sequence diagram: $p=0.01$ e $p=0.002$.
Correlazione	Nessuna correlazione significativa percezione-performance dopo Bonferroni.

Interpretazione consentita

Con scenario testuale e sequence diagram già disponibili, il DFD aggiuntivo non migliora significativamente la correttezza dei novizi. La percezione positiva non costituisce prova di efficacia.

Limiti principali

- Studenti, non professionisti; due livelli accademici e due modalità di esecuzione.
- Sequence diagram fornito a tutti; nessun gruppo senza modello.
- Ground truth binaria e una sola forma di minaccia fabbricata.
- Self-report, ground truth autoriale e Δ di equivalenza scelto dagli autori.
- Possibile refuso interno: 98 partecipanti totali ma un passaggio riporta 67/100.

Rapporto con DDTA

Base Analysis	Fatti su componenti, processi, store, flow, interaction, boundary, assumption e provenance.
Proiezioni	DFD e sequence view generate dalla stessa rappresentazione neutrale, senza collassarle.
Overlay	STRIDE/threat validation con description, assumption, evidence cue, rationale e review state.
Evaluation	Misurare task correctness, perceived utility, review cost, maintenance cost e longitudinal utility.

Claim non supportati

- DFD inutili in generale o da eliminare.
- Sequence diagram semanticamente equivalente al DFD.
- Risultati generalizzabili a esperti o threat elicitation.
- Test sufficienti senza modelli, conoscenza tecnica o review.

Gap

Resta aperta la derivazione governata degli artefatti da documentazione versionata, la conservazione della provenance degli information cue e l'aggiornamento delle conclusioni quando cambiano fonti, assunzioni, architettura, codice o runtime.